Guia tecnica de AgeCare

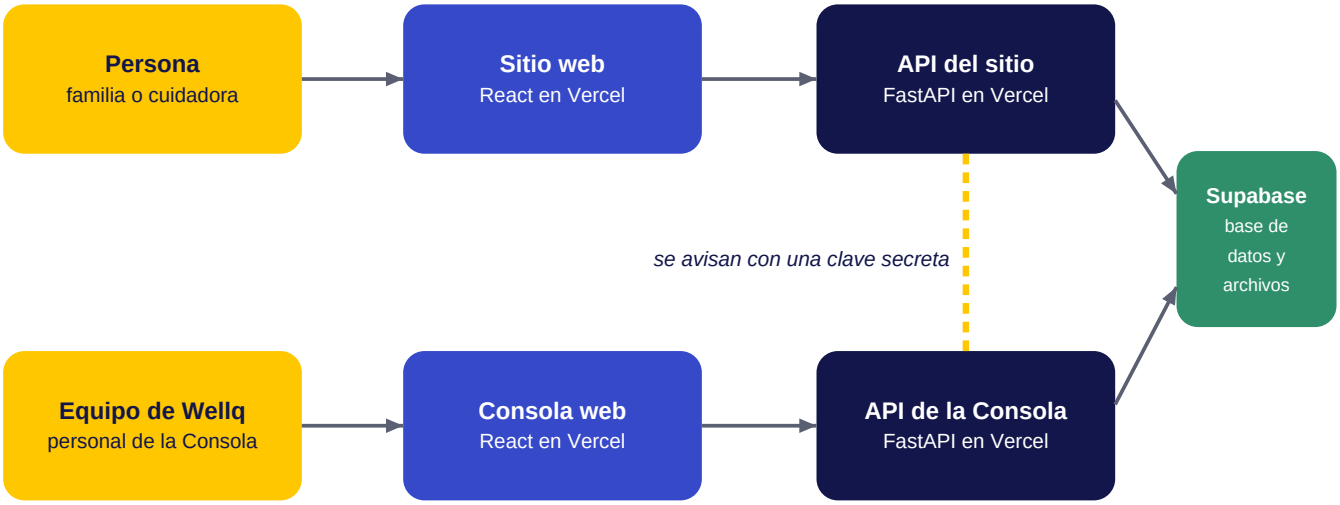
Herramientas, decisiones y evidencias medidas. Pensada para estudiar y para responder preguntas del profesor. Cifras tomadas del repositorio y de las pruebas del 12 de noviembre de 2026.

1. Que es el proyecto

Proyecto de titulo (Duoc UC) para Wellq Co / Alloxentric. Nuestro modulo es el **marketplace de cuidadoras con resenas, puntos de fidelizacion y ranking**, integrado a la Consola de Administracion. Como desarrollo adicional hicimos el sitio publico que simula la app de familias y cuidadoras, sobre la Especificacion de Endpoints Backend v1 del cliente. Tamano aproximado: 116 endpoints, 39 tablas, unas 14.400 lineas de codigo y mas de 50 commits.

Pieza	Tecnologia	Detalle
Consola (frontend)	React 19, TypeScript 6, Vite 8, React Router 7	SPA; roles que ven distintas secciones (Marketplace y Fidelizacion)
API de la Consola (backend)	Python, FastAPI >=0.121, SQLAlchemy 2 asincrono, asyncpg, Alembic, Pydantic 2	70 endpoints, 25 tablas; migraciones 0001 a 0007; roles admin, soporte, analista, editor, moderador; MFA TOTP
Sitio publico (frontend)	React 19, TypeScript 6, Vite 8	Familias y cuidadoras: registro, busqueda, chat, contratacion, resenas
API del sitio (backend-general)	Mismo stack, sin Alembic (esquema por create_all y parches idempotentes)	46 endpoints, 14 tablas; subida de fotos y documentos validando el contenido real del archivo
Base y archivos	Supabase: PostgreSQL 16 y Storage (region Sao Paulo)	RLS activado en tablas de chat; bucket de archivos (publico hoy, ver limitaciones)
Despliegue	Vercel (4 proyectos, plan Hobby), GitHub Actions	main = produccion con auto-deploy; funciones fijadas en region gru1
Local y pruebas	Docker Compose, pytest, Playwright, Node	Docker solo en desarrollo

2. Arquitectura y comunicacion entre APIs



Las flechas son llamadas por internet (HTTPS). Cada caja de color es un proyecto distinto en Vercel.

- **Dos aplicaciones independientes** con base compartida. El sitio es la fuente de verdad de usuarios, chats y trabajos; la Consola es la fuente de verdad de la aprobacion del staff, resenas moderadas y puntos.
- **Servidor a servidor** con la cabecera X-Internal-Key (clave compartida). Sitio a Consola: perfil publicado, documentos subidos, resenas nuevas, borrado de cuenta. Consola a Sitio: estado del perfil (aprobada/suspendida), revision de documentos, moderacion de resenas, eliminacion de perfil.
- **Consistencia:** si una accion del staff cambia lo que ven las familias y el aviso falla, la accion se cancela con 502 y se repite (asi no quedan dos verdades). Los avisos del sitio a la Consola son de mejor esfuerzo: no deben romper lo que hizo la persona.
- **Esquema:** la Consola usa Alembic; ademas, al primer uso de cada instancia, un parche idempotente agrega columnas faltantes. Asi los despliegues desde GitHub no exigen pasos manuales en Supabase.

3. Reglas de negocio destacadas

Regla	Como funciona
Aprobacion	Una cuidadora solo aparece si el staff aprobo cedula y antecedentes y aprobo el perfil (y se resolvio el cobro de verificacion).
Puntos por resena	Trabajo cerrado con resena: +10. Bono 4 o 5 estrellas: +5. 3 estrellas: neutra. 2 estrellas: -5. 1 estrella: -15. Total = suma del historial, sin contar resenas archivadas (reglas en backend/app/loyalty.py).
Moderacion de resenas	El staff ve las resenas de cada cuidadora una por una y puede archivar (reversible; no cuenta para nota ni puntos), restaurar o eliminar. Queda en auditoria y el sitio publico se actualiza.
Un trabajo a la vez	Una cuidadora con trabajo activo no puede ser solicitada por otra familia.
Chats	Se borran a los 7 dias (limpieza como maximo cada 5 minutos por instancia).
Eliminar datos	Una familia elimina familiares y su cuenta (con contrasena); no se puede si hay un trabajo en curso. El staff puede eliminar un perfil de cuidadora, que tambien borra su cuenta en el sitio.

Regla	Como funciona
Rentabilidad (modulo de Julio)	Cobro unico de verificacion a cuidadoras nuevas (9.990 CLP; estados pendiente, pagado, eximido, con referencia de pago) y articulos de apoyo patrocinados con comision y registro de clics.

4. Seguridad

Control	Implementacion	Evidencia
Contrasenas	Argon2id (19 MiB, 2 pasadas, 1 hilo: minimo OWASP); calculo en hilos aparte	Hash nunca sale en respuestas
Sesion	JWT de acceso corto + refresh con rotacion; reutilizar un refresh revoca la sesion	Pruebas de token falso, vencido, sin firma, otro algoritmo
Fuerza bruta	Bloqueo de 15 minutos tras 5 fallos; mensaje identico para correo inexistente y clave mala; mismo tiempo de respuesta	Hallazgo: en el sitio el contador no se guardaba. Corregido y con prueba
Inyeccion SQL	Consultas parametrizadas (SQLAlchemy) + validacion Pydantic	8 cargas tipicas en login, filtros, textos e IDs
Permisos	Cada ruta exige sesion; roles en la Consola; datos de otras familias devuelven 403/404; claves internas	Prueba que recorre todas las rutas del esquema OpenAPI sin sesion
Archivos	Se valida la firma del archivo (no solo la extension); limite de 4 MB; nombres imposibles de adivinar	Pruebas de archivo falso y de tamano
Cabeceras	nosniff, X-Frame-Options DENY, HSTS, Referrer-Policy, Permissions-Policy; CORS solo a las webs propias	Verificado tambien en produccion
Auditoria	La Consola registra acciones del staff (aprobar, suspender, eliminar, moderar)	Tabla de auditoria

5. Rendimiento: que medimos y que cambiamos

Probamos con PostgreSQL 16 real en Docker y un script propio (pruebas/carga.mjs) que simula familias, cuidadoras y staff con un recorrido completo. El PC de pruebas es de escritorio y compartido con otros programas, asi que sirve para encontrar fallas y comparar antes y despues, no para prometer tiempos.

Hallazgo	Efecto	Solucion
APIs en Washington, base en Sao Paulo	Cada peticion pagaba el viaje varias veces: un login de correo inexistente (1 consulta) tardaba 1,3 s	regions: gru1 en vercel.json. Medido en produccion: 0,3 s (x4) y mensaje x-vercel-id pasa de gru1::iad1 a gru1::gru1
Argon2 en el hilo principal	Mientras uno iniciaba sesion, todos esperaban	Hilos aparte con tope y parametros OWASP: ~14 a ~60 inicios de sesion por segundo
Respondia antes de guardar	La peticion siguiente podia dar 403/404 al azar	Depends(get_db, scope="function"): el commit ocurre antes de responder
Pool de conexiones agotado	Errores 500 con cientos de usuarios	Conexiones se liberan antes de esperar a la otra API o al hash; pool configurable (20+20)
3 DELETE de limpieza por visita al chat	La mitad de las consultas del chat	Limpieza como maximo cada 5 minutos

Hallazgo	Efecto	Solucion
Consulta por resena en el listado	Lento con muchas resenas	Una sola consulta agrupada

Escenario (PC de pruebas)	Peticiones	Errores	Mediana	p95
100 usuarios simultaneos, uso normal	904	0	0,6 s	5,8 s
300 usuarios simultaneos, uso normal	2.779	0	4,4 s	16,8 s
500 usuarios simultaneos, uso normal	3.903	14 %	7,4 s	43 s
100 usuarios creando cuenta a la vez	937	0	1,4 s	9,6 s

Lectura honesta: en una sola maquina de escritorio aguantamos 300 usuarios simultaneos sin errores pero con esperas; 500 la saturan (se agotan conexiones mientras las peticiones hacen fila). En Vercel cada peticion corre en su propia funcion y escala sola, por lo que el cuello pasa a ser el limite de conexiones de Supabase. No hicimos prueba de carga contra produccion para no crear miles de cuentas en datos reales.

6. Pruebas

Capa	Cantidad	Que cubre
Automaticas de la Consola	83	Reglas de negocio, roles, documentos, puntos, moderacion, monetizacion, seguridad
Automaticas del sitio	94	Flujos de usuario, chat, contratacion, resenas, eliminacion de datos, seguridad
De seguridad (dentro de las anteriores)	78	SQL, XSS, tokens, rutas sin sesion, IDOR, fuerza bruta, cabeceras, CORS
Recorrido E2E con navegador	34 pasos	Registro a resena y ranking. Con el PC cargado el resultado vario entre 12 y 32 sin cambiar codigo: son esperas de la propia prueba
Migraciones	7	Alembic 0001 a 0007 sobre PostgreSQL vacio, sin errores
CI (GitHub Actions)	4 trabajos	Pruebas de ambas APIs y compilacion de ambas webs en cada subida

7. Limitaciones conocidas (decirlas antes de que pregunten)

- El bucket de documentos es publico (URLs imposibles de adivinar). Para datos reales hay que pasarlo a privado con URLs firmadas.
- No hay recuperacion de contrasena por correo ni textos legales publicados.
- Plan Hobby de Vercel es solo para uso no comercial; el lanzamiento comercial requiere plan Pro.
- Las funciones de Vercel se duermen: la primera carga tras un rato puede tardar unos segundos.
- La prueba de carga se hizo en un PC local, no en produccion.
- El sitio publico simula la app movil: la integracion con la app real del cliente depende de la Especificacion v1.

8. Que haremos despues

- Integrar nuestro modulo con el repositorio de administracion comun (otro equipo mantiene un esquema multi-tenant); la conversacion con ese equipo ya partio.

- Pagos reales para la verificacion y los articulos; recuperacion de contrasena; bucket privado.
- Cache para el ranking y paginacion por cursor si el volumen crece.